

Automated GDPR Compliance: A Data Discovery Concept for Bosch

Concept Paper for the Identification and Categorization of Personal Data on Corporate Drives and SharePoint Sites

Introduction: Objective and Background

As part of a 48-hour hackathon, an innovative software concept is being developed to enable the automated identification and categorization of personal and GDPR-relevant data on corporate drives, SharePoint sites, OneDrives, and other data sources. The goal is to sustainably identify sensible data and delete it when required. The solution will be developed as a prototype (Proof of Concept) and serve as a basis for future scaling.

Legal Basis:

The General Data Protection Regulation (GDPR) is a comprehensive data privacy law enacted by the European Union (EU). It regulates how organizations worldwide must handle the personal data of individuals located in the EU. The primary goal is to give individuals control over their personal data and to unify data privacy and security laws across Europe.

Relevant Articles:

Article	Title	Relevance to Data Management
Article 5	Principles relating to processing of personal data	This article sets the core principles. For data management, data minimisation (only process necessary data) and storage limitation (don't store data longer than needed) are crucial. Tools help enforce this by identifying and deleting obsolete data.
Article 17	Right to erasure ('right to be forgotten')	This gives individuals the right to have their personal data deleted by an organization. A data management tool is essential to fulfill these requests by finding and securely deleting the relevant data from all systems, including unstructured files.
Article 25	Data protection by design and by default	This principle requires organizations to integrate data protection measures into their processing activities and systems from the very beginning. Using an automated tool to manage data lifecycles is a perfect example of implementing "privacy by design."

To properly secure personal data, you first need to know where it is. Tools that scan for and classify personal data are fundamental to understanding the risk landscape and applying appropriate security measures to protect it.

Problem Statement: GDPR and Data Management

With the introduction of the General Data Protection Regulation (GDPR), companies are obligated to manage personal data transparently and delete it after the retention period is exceeded. In large organizations like Bosch, the multitude and distribution of data sources, approximately 300,000 OneDrives and globally distributed shared drives and SharePoint sites, pose a significant challenge. Manual auditing is hardly feasible, creating a high demand for automated tools that can reliably identify and classify data relevant to data protection.

Solution Approach: Software Concept and AI Implementation

The planned software combines modern AI technologies with classic search mechanisms to detect personal and sensitive data across various corporate databases. The scan will be conducted in two stages: first, a complete search (full scan) is performed, followed by subsequent checks at regular intervals that only review files modified since the last scan (delta scan). The AI will provide suggestions for data categorization, with the final review and deletion of the file being conducted by a human to ensure compliance. The discovered data can always be attributed to a person, either as a direct owner (e.g., OneDrive) or indirectly as a "Master of Data" (e.g., SharePoint, Shared Drives).

Scope: Artifacts to be Implemented

Priority 1: Scan Logic:

The primary goal of the scan logic is to effectively identify personal data within unstructured content. The technical approach to achieve this is deliberately left open, allowing teams to be creative and innovative. The choice of implementation is yours—whether it's an AI-driven model, a classic template-matching system, or a hybrid solution, the key success factor will be the accuracy and reliability of the results.

Priority 2: Frontend (User View):

When an employee logs in, this interface should:

- **Show Personal Scan Results:** Display a clear list of only the files the logged-in user is responsible for that have been flagged by the scan.
- **Enable User Action:** Allow the user to click on a file to understand the issue and take a simple, guided action. For example, they could confirm that the data is required for business reasons or acknowledge that they need to clean up the file.

Priority 3: Frontend (Admin View):

An overview dashboard that serves as a central control panel. This view should provide key metrics and a high-level summary of the data landscape. Essential key numbers to display include:

- Total number of scanned files.
- Total size (GB/TB) of the scanned data.
- Number of files identified with potential findings.

(Priority 4: OneDrive, SharePoint, & Fileshare Connectors)

The foundation of this data discovery solution lies in its ability to access and read data from various corporate sources. For this hackathon, your task is to develop the automation that enables the system to reliably connect to and read content from these specified data sources.

Evaluation criteria:

- **Scan accuracy (What % of the files are correctly identified, taken into consideration false positives and negatives)**
- **Reproducibility (Repeated scans shall produce the same outcome)**

- **Scan speed (How much time is consumed to get through a defined amount of data)**
- **Resource intensity (How much computing power is required to fulfill the task)**

- **Example for personal data:**

First name, last name

- Username / login name
- Email address
- Signature
- (Photo / video of a person)
- Phone number (mobile / landline)
- Fax number
- Home address
- Billing / shipping address
- Passport number
- ID card number
- Driver's license number
- Travel history

Git repo with some examples:

<https://github.com/a-klumpp/GDPR-data-samples>

Retention Period: 3 Years